COMPTIA SECURITY+ SY0-701 DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.1 · Wireless Security Settings

Mestre CyberSec · **Aula 4.1 — Wireless Security Settings** (10:54) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Resumo Executivo da Aula:** Config do AP: WPA3/SAE (moderno), WPA2/TKIP e WEP quebrados proibidos; RADIUS centralizado; WPS (Wi-Fi Protected Setup) inseguro — DISABLE.

💡 Highlights que a prova CompTIA cobra

- WPA3/SAE = moderno; WEP/WPA nunca
- WPS (o botãozinho) é INSEGURO — desabilita sempre

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'deprecate WEP/WPA'=use WPA2/3

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.1 — Wireless Security Settings)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• WPA3 (Acesso Protegido Wi-Fi 3)

O padrão moderno atual de segurança wireless que usa SAE (Autenticação Simultânea de Iguais) para autenticação baseada em senha, fornecendo proteção contra ataques de dicionário offline e sigilo direto (forward secrecy).

⚠️ ***Armadilha CompTIA:*** *On the exam, WPA3 is always the BEST/correct answer when available; if WPA3 is mentioned as an option, choose it over WPA2.*

• SAE (Autenticação Simultânea de Iguais)

Mecanismo seguro de troca de chaves usado no WPA3 que substitui o handshake de 4 vias do WPA2, impedindo ataques de dicionário/Força-bruta offline ao exigir um handshake ativo para cada tentativa de senha.

⚠️ ***Armadilha CompTIA:*** *When the question describes a WPA3 attack mitigation for offline brute-force, the answer is SAE (not just WPA3 generically).*

• WPA2 (Acesso Protegido Wi-Fi 2)

O padrão de segurança wireless da geração anterior usando PSK (Personal) ou 802.1X (Enterprise) com criptografia AES-CCMP; ainda aceitável, mas considerado legado em comparação ao WPA3.

⚠️ ***Armadilha CompTIA:*** *WPA2 with AES-CCMP is acceptable; WPA2 with TKIP is DEPRECATED — never choose TKIP as an encryption method on the exam.*

• TKIP (Protocolo de Integridade de Chave Temporal)

Um protocolo de criptografia mais antigo usado com WPA/WPA2 que foi descontinuado devido a vulnerabilidades; substituído pelo mais seguro AES-CCMP.

⚠️ ***Armadilha CompTIA:*** *TKIP is a DEPRECATED/INSECURE option. If you see TKIP as an answer choice on the exam, it is a distractor — choose AES-CCMP or SAE instead.*

• WEP (Privacidade Equivalente à Cabeada)

O protocolo original de segurança wireless, agora completamente quebrado e quebrável em segundos; NUNCA deve ser usado em nenhum ambiente moderno.

⚠️ ***Armadilha CompTIA:*** *Any question mentioning WEP = 'deprecate/disable immediately.' It is the WORST answer for wireless security; migrating to WPA2/WPA3 is required.*

• RADIUS (Serviço Remoto de Autenticação de Usuário)

Protocolo centralizado de servidor AAA (Autenticação, Autorização e Accounting) usado com 802.1X para autenticação wireless Enterprise, fornecendo credenciais por usuário escaláveis em vez de uma PSK compartilhada.

⚠️ ***Armadilha CompTIA:*** *When the scenario says 'centralized wireless authentication for an enterprise,' the answer is WPA2/WPA3 Enterprise with RADIUS + 802.1X, NOT PSK.*

• 802.1X

Padrão de Controle de Acesso à Rede (NAC) baseado em porta que autentica dispositivos/usuários que se conectam a uma rede cabeada ou wireless via um autenticador (AP) e servidor de autenticação (RADIUS).

⚠️ ***Armadilha CompTIA:*** *Distinguish Personal mode (PSK/shared key) vs Enterprise mode (802.1X + RADIUS + per-user). Enterprise is always preferred for corporate environments.*

• WPS (Configuração Protegida Wi-Fi)

Recurso de conveniência que simplifica a conexão de dispositivos a uma rede Wi-Fi via PIN ou botão de pressão; considerado altamente inseguro e vulnerável a ataques de força-bruta no PIN de 8 dígitos.

⚠️ ***Armadilha CompTIA:*** *ALWAYS DISABLE WPS on every AP — Professor Messer's #1 wireless hardening tip. The push-button/PIN feature is a guaranteed exam trap.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um hospital está renovando sua infraestrutura sem fio. A equipe de segurança quer eliminar o risco de ataques de dicionário offline contra handshakes capturados do WPA2-Personal para a SSID de convidados. Qual configuração de segurança sem fio deve ser definida nos APs para a SSID de convidados?

A) WPA3-Personal com SAE

B) WPA2-Personal com AES-CCMP

C) WPA2-Enterprise com PEAP-MSCHAPv2

D) Autenticação aberta com portal cativo

QUESTÃO 2 · CENÁRIO DE EXAME

Os novos leitores de código de barras sem fio de uma empresa de logística só suportam WPA2-Personal com TKIP. A política de segurança proíbe TKIP por ser criptograficamente fraco. O que o administrador deve fazer?

A) Ativar modo misto WPA2/WPA3 com TKIP para os leitores.

B) Substituir ou atualizar os leitores para que suportem AES-CCMP ou WPA3 e, em seguida, desativar o TKIP.

C) Configurar uma SSID oculta com filtragem MAC para os leitores.

D) Configurar o AP com WEP para compatibilidade dos leitores e segmentá-los em uma VLAN.

QUESTÃO 3 · CENÁRIO DE EXAME

Uma loja de varejo ainda usa WEP em um AP para coletores de inventário antigos. Uma avaliação recente classifica o WEP como achado crítico. Qual ação corrige melhor o achado?

A) Aumentar o comprimento da chave WEP de 64 bits para 128 bits.

B) Trocar a chave WEP semanalmente.

C) Migrar os coletores para WPA2/WPA3 e desativar o WEP no AP.

D) Ocultar a SSID e reduzir a potência de transmissão.

QUESTÃO 4 · CENÁRIO DE EXAME

Uma universidade quer que cada aluno e funcionário se autentique no Wi-Fi com credenciais individuais. A equipe de segurança também precisa de contabilização centralizada e da capacidade de revogar o acesso de um usuário sem alterar uma chave compartilhada. Qual configuração de AP deve ser usada?

A) WPA3-Personal com SAE

B) WPA2-Personal com uma longa frase secreta compartilhada

C) WPA2-Enterprise com 802.1X e RADIUS

D) WPS com configuração por botão

QUESTÃO 5 · CENÁRIO DE EXAME

Uma pequena empresa habilita WPS no AP para permitir que os funcionários conectem impressoras facilmente. Um auditor alerta que o método PIN pode ser quebrado por força bruta. Qual recomendação é mais apropriada?

A) Alterar o PIN do WPS a cada 30 dias.

B) Usar WPS por botão apenas durante o horário comercial.

C) Restringir WPS aos endereços MAC das impressoras.

D) Desativar o WPS e usar WPA3 ou WPA2 com credenciais fortes ou 802.1X.

QUESTÃO 6 · CENÁRIO DE EXAME

Uma empresa teme que atacantes que obtiverem a frase secreta do Wi-Fi consigam conectar laptops não autorizados à SSID corporativa. A equipe de rede deve garantir que apenas dispositivos gerenciados pelo domínio possam entrar. Qual configuração atende melhor a esse requisito?

A) WPA3-Personal com SAE e uma frase secreta complexa.

B) SSID oculta com potência de sinal reduzida.

C) WPA2-Enterprise com 802.1X, EAP-TLS e RADIUS.

D) WPA2-Personal com filtragem de endereço MAC.

QUESTÃO 7 · CENÁRIO DE EXAME

Uma organização quer implantar WPA3, mas precisa suportar tablets antigos somente WPA2 por seis meses. Qual abordagem de implantação é mais apropriada durante a transição?

A) WPA2 com TKIP porque é compatível com clientes WPA3.

B) Modo somente WPA3 para forçar a substituição imediata.

C) Modo misto WPA3/WPA2 enquanto planeja aposentar dispositivos somente WPA2.

D) WEP com 802.1X porque suporta ambos os tipos de cliente.

QUESTÃO 8 · CENÁRIO DE EXAME

Um analista de segurança captura um handshake de quatro vias do WPA2-Personal e tenta quebrá-lo offline. O diretor de TI pergunta qual upgrade mitiga diretamente esse ataque. Qual tecnologia deve ser recomendada?

A) TKIP em WPA2-Personal

B) RADIUS com PAP

C) PIN do WPS

D) SAE em WPA3-Personal

QUESTÃO 9 · CENÁRIO DE EXAME

Um administrador de rede está configurando um novo AP para usar 802.1X. O servidor RADIUS já está em execução. Qual etapa deve ser realizada no AP?

A) Configurar uma única chave pré-compartilhada para todos os usuários do RADIUS.

B) Ativar WPS para que os clientes recebam o certificado RADIUS.

C) Configurar o AP como cliente RADIUS e especificar o endereço do servidor RADIUS e o segredo compartilhado.

D) Definir o AP para WEP e mapear usuários para VLANs.

QUESTÃO 10 · CENÁRIO DE EXAME

A política sem fio de uma empresa afirma que nenhum protocolo de criptografia obsoleto pode ser usado em APs corporativos. Durante uma auditoria, o administrador encontra um AP transmitindo uma rede WPA2 com TKIP habilitado. Qual é a melhor ação corretiva?

A) Ativar WPS para simplificar a reconexão dos clientes após a mudança.

B) Mover o AP para uma VLAN de convidados e manter TKIP para compatibilidade.

C) Alterar o comprimento da chave TKIP para 256 bits.

D) Desativar o TKIP e configurar AES-CCMP com WPA2 ou WPA3.

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — WPA3-Personal com SAE

WPA3-Personal com SAE usa Simultaneous Authentication of Equals e resiste a ataques de dicionário offline em handshakes capturados. WPA2-Personal com AES-CCMP ainda usa uma frase secreta compartilhada e permanece vulnerável a captura e quebra offline. WPA2-Enterprise fornece autenticação individual, mas o cenário foca no risco de modo pessoal da SSID de convidados. Autenticação aberta com portal cativo não fornece criptografia sem fio.

Questão 2: Alternativa B — Substituir ou atualizar os leitores para que suportem AES-CCMP ou WPA3 e, em seguida, desativar o TKIP.

O TKIP é obsoleto e proibido, portanto não deve permanecer ativado apenas para dispositivos legados. A correção definitiva é substituir ou atualizar os leitores para suportarem AES-CCMP ou WPA3 e então desativar o TKIP. SSID oculta, filtragem MAC e WEP não corrigem a criptografia fraca, e o WEP é ainda menos seguro.

Questão 3: Alternativa C — Migrar os coletores para WPA2/WPA3 e desativar o WEP no AP.

O WEP é quebrado independentemente do comprimento ou da rotação da chave, então deve ser desativado. Migrar os coletores para WPA2 ou WPA3 e desativar o WEP corrige a causa raiz. Aumentar chave, rotacionar chaves, ocultar SSID e reduzir potência não corrigem as fraquezas criptográficas do WEP.

Questão 4: Alternativa C — WPA2-Enterprise com 802.1X e RADIUS

WPA2-Enterprise com 802.1X e RADIUS suporta autenticação individual de usuários, contabilização centralizada e revogação por usuário. WPA3-Personal e WPA2-Personal usam credenciais compartilhadas, então revogar um usuário exige alterar a chave compartilhada para todos. WPS é inseguro e não é um método de autenticação empresarial.

Questão 5: Alternativa D — Desativar o WPS e usar WPA3 ou WPA2 com credenciais fortes ou 802.1X.

O PIN do WPS é vulnerável a ataques de força bruta e deve ser desativado. A recomendação segura é desligar o WPS e usar WPA3/WPA2 com credenciais fortes ou 802.1X. Alterar o PIN, agendar o botão ou filtrar MAC não elimina a superfície de ataque do WPS.

Questão 6: Alternativa C — WPA2-Enterprise com 802.1X, EAP-TLS e RADIUS.

WPA2-Enterprise com 802.1X, EAP-TLS e RADIUS pode exigir certificados de dispositivo e validar cada dispositivo antes do acesso à rede. WPA3-Personal e WPA2-Personal dependem de credenciais compartilhadas, então qualquer pessoa com a frase secreta pode se conectar. SSID oculta e filtragem MAC são controles fracos que podem ser contornados.

Questão 7: Alternativa C — Modo misto WPA3/WPA2 enquanto planeja aposentar dispositivos somente WPA2.

O modo misto WPA3/WPA2 permite que clientes compatíveis com WPA3 usem WPA3 enquanto oferece suporte temporário a dispositivos somente WPA2. WPA2 com TKIP usa protocolo obsoleto, somente WPA3 quebraria os tablets imediatamente, e WEP com 802.1X não é uma combinação segura válida.

Questão 8: Alternativa D — SAE em WPA3-Personal

O SAE no WPA3-Personal substitui o handshake PSK do WPA2-Personal por uma troca de autenticação resistente, impedindo ataques de dicionário offline em handshakes capturados. TKIP é obsoleto, RADIUS com PAP é inseguro para credenciais, e o PIN do WPS é vulnerável a força bruta.

Questão 9: Alternativa C — Configurar o AP como cliente RADIUS e especificar o endereço do servidor RADIUS e o segredo compartilhado.

Para 802.1X, o AP atua como autenticador e deve ser configurado como cliente RADIUS com o endereço do servidor RADIUS e um segredo compartilhado. Uma única chave pré-compartilhada é WPA2-Personal, WPS é inseguro e não relacionado, e WEP não deve ser usado.

Questão 10: Alternativa D — Desativar o TKIP e configurar AES-CCMP com WPA2 ou WPA3.

O TKIP é um protocolo de criptografia obsoleto e deve ser removido dos APs corporativos. A ação correta é desativar o TKIP e usar AES-CCMP com WPA2 ou WPA3. Ativar WPS adiciona risco, mover para VLAN de convidados não corrige a criptografia fraca, e alterar o comprimento da chave TKIP não o torna aceitável.